Cookie & Session

HTTP의 Stateless

- HTTP 프로토콜은 클라이언트의 상태정보를 유지 않음
- 동일 클라이언트의 현재 요청과 이전 요청을 식별하지 못함
- 클라이언트의 상태 정보 유지가 필요한 경우(로그인 상태 정보 유지, 장바구니 등) 클라이언트 기술로는 쿠키(cookie), 서버 기술로 세션(session)이 있음

- 쿠키(cookie)

  ❶ 사용자 컴퓨터에 설치되는 작은 데이터 기록 정보 파일

  ❷ 쿠키에는 해당 웹 사이트에 방문했던 이름, 값, 만료 날짜, 경로 정보등이 담겨 있음

  ❸ 일정시간 동안 데이터를 저장할 수 있어 로그인 상태를 유지하거나 사용자 정보를 일정 시간동안 유지해야 할 때 주로 사용

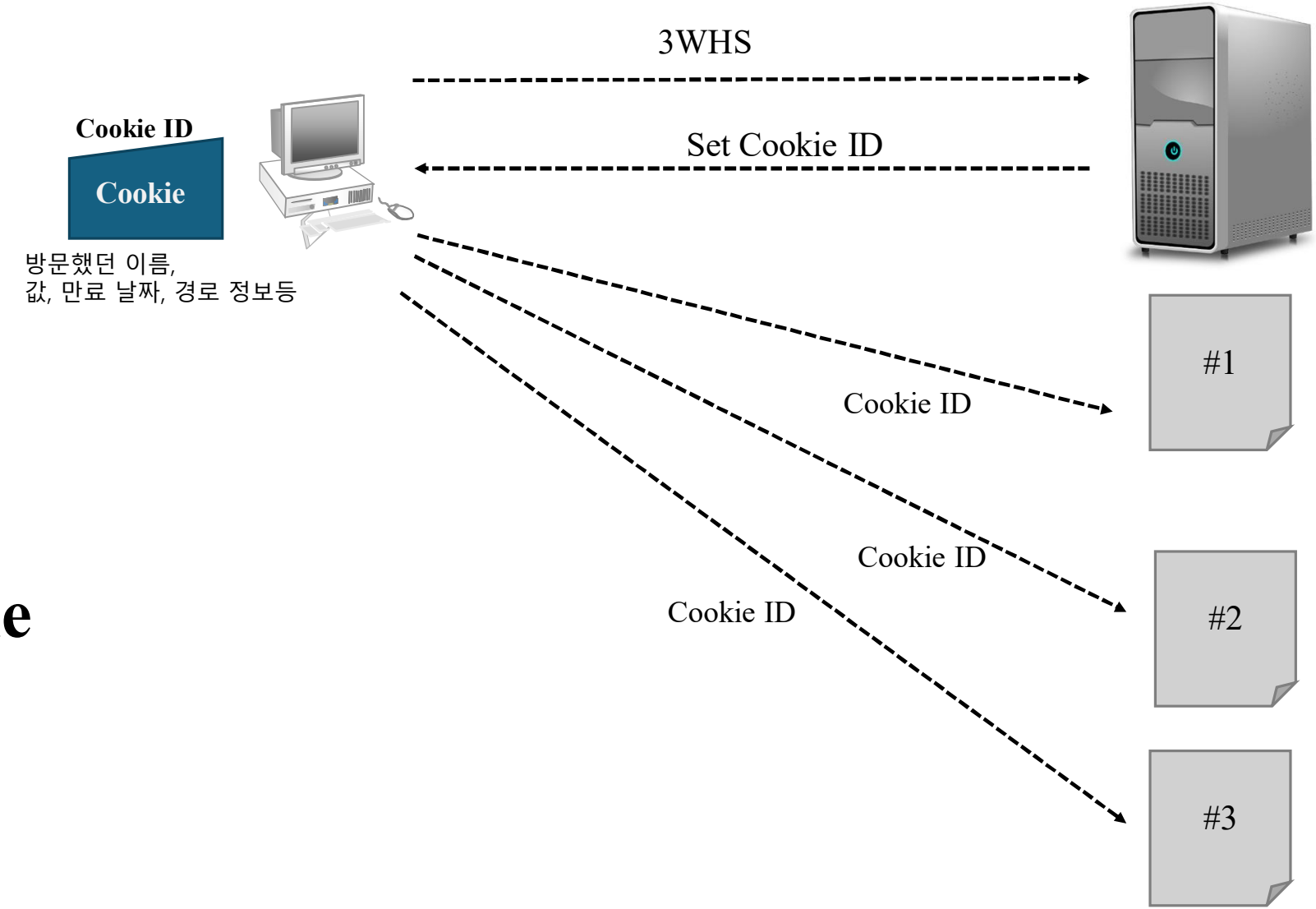
- 세션(session)

  ❶ 서버 메모리에 저장되는 정보

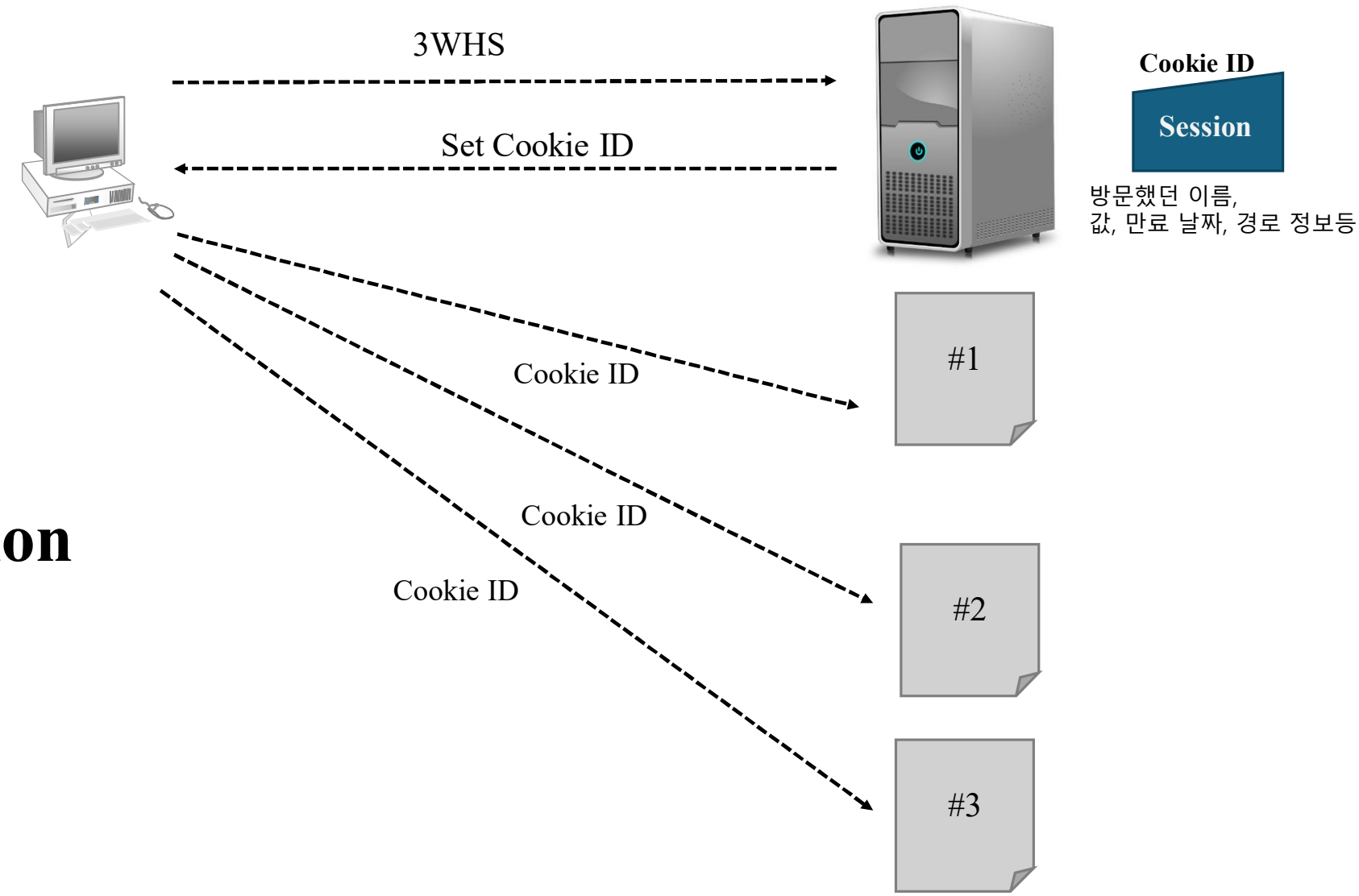
  ❷ 서버에 저장되기 때문에 쿠키와 달리 사용자 정보가 노출되지 않음

  ❸ 세션을 사용하더라도 클라이언트의 세션ID를 공격자가 가로채어 변조가 가능

Cookie


3WHS
Set Cookie ID
Cookie ID
Cookie
방문했던 이름,
값, 만료 날짜, 경로 정보등
Cookie ID
Cookie ID
Cookie ID
#1
#2
#3

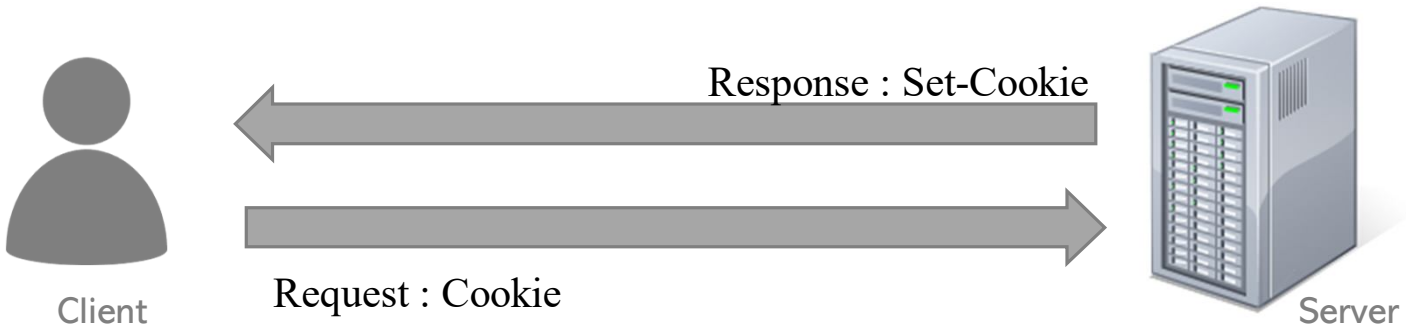
Session


3WHS
Set Cookie ID
Cookie ID
Session
방문했던 이름,
값, 만료 날짜, 경로 정보등
Cookie ID
Cookie ID
Cookie ID
#1
#2
#3

Cookie를 위한 헤더 필더

■ Cookie는 유저 식별과 상태 관리에 사용되고 있는 기능

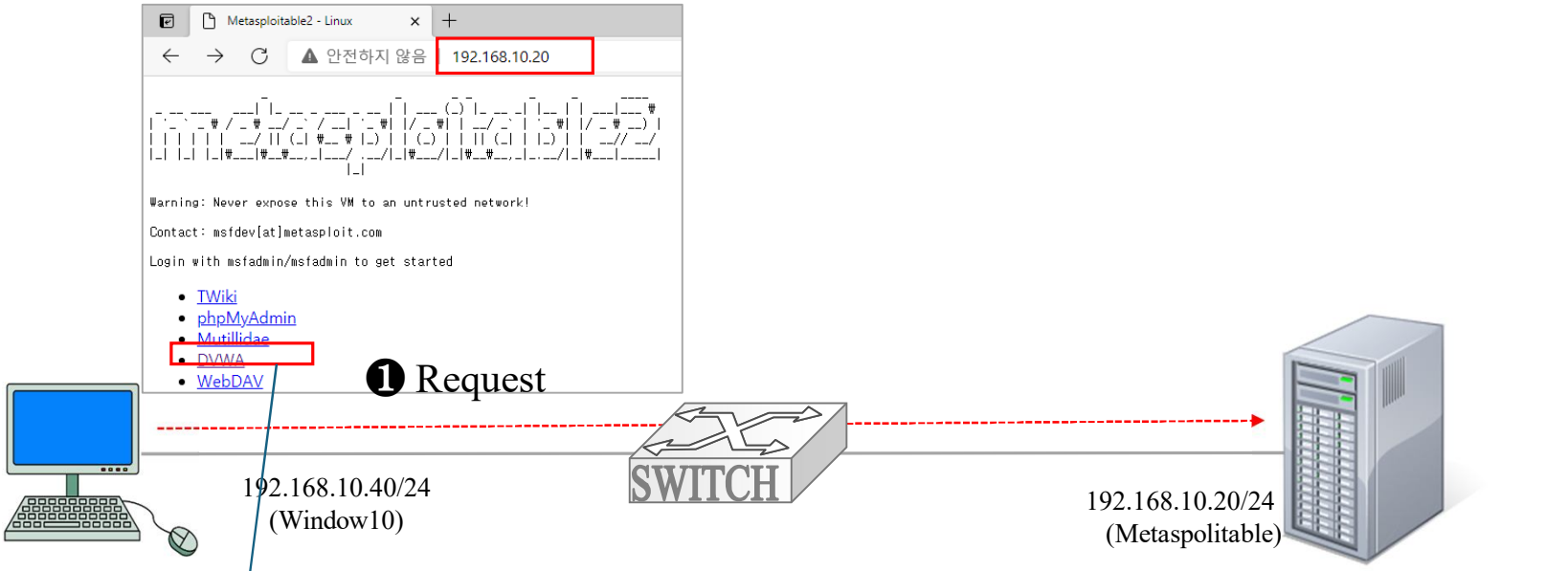
- Set-Cookie : 상태 관리 개시를 위한 쿠키 정보
- Cookie : 서버에서 수신한 쿠키 정보



Set-Cookie

```
Set-Cookie : status-enable; expire=Tue,05 Jul 2020 07:26:31 GMT;
Path=/; domain=.test.com;
```

NAME=VALUE	쿠키에 부여된 이름과 값
Expires=DATE	쿠키 유효기간(지정되지 않은 경우 브라우저 닫을때까지)
Path=PATH	쿠키 적용 대상이 도는 서버 상의 디렉터리
Domain=도메인명	쿠키 적용 대상이 도는 도메인명(지정되지 않을 경우 쿠키를 생성한 서버의 도메인)
Secure	HTTPS로 통신하고 있는 경우에만 쿠키 송신
HttpOnly	쿠키를 JAVAscript에서 액세스 하지 못하도록 제한



55	http://192.168.10.20	GET	/dvwa/		302	445	HTML				192.168.10.20	PH
56	http://192.168.10.20	GET	/dvwa/login.php		200	1599	HTML	php	Damn Vulnerable Web ...		192.168.10.20	
73	http://192.168.10.20	POST	/dvwa/login.php	✓	302	354	HTML	php			192.168.10.20	
74	http://192.168.10.20	GET	/dvwa/login.php		200	1638	HTML	php	Damn Vulnerable Web ...		192.168.10.20	
101	http://192.168.10.20	POST	/dvwa/login.php	✓	302	354	HTML	php			192.168.10.20	
102	http://192.168.10.20	GET	/dvwa/login.php		200	1638	HTML	php	Damn Vulnerable Web ...		192.168.10.20	

Request ❶

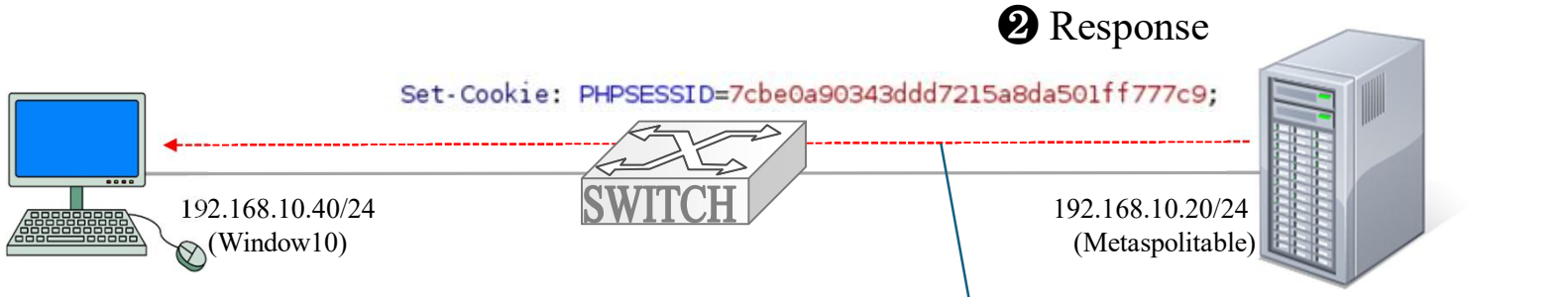
Pretty | Raw | \n | Actions

```
1 GET /dvwa/ HTTP/1.1
2 Host: 192.168.10.20
3 Upgrade-Insecure-Requests: 1
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
  like Gecko) Chrome/89.0.4389.90 Safari/537.36 Edg/89.0.774.63
5 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;
  q=0.8,application/signed-exchange;v=b3;q=0.9
6 Referer: http://192.168.10.20/
7 Accept-Encoding: gzip, deflate
8 Accept-Language: ko,en;q=0.9,en-US;q=0.8
9 Connection: close
10
```

Response

Pretty | Raw | Render | \n | Actions

```
1 HTTP/1.1 302 Found
2 Date: Thu, 08 Apr 2021 08:17:12 GMT
3 Server: Apache/2.2.8 (Ubuntu) DAV/2
4 X-Powered-By: PHP/5.2.4-2ubuntu5.10
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT
6 Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
7 Pragma: no-cache
8 Set-Cookie: PHPSESSID=7cbe0a90343ddd7215a8da501ff777c9; path=/
9 Set-Cookie: security=high
10 Location: login.php
11 Content-Length: 0
12 Connection: close
13 Content-Type: text/html
```



55	http://192.168.10.20	GET	/dvwa/		302	445	HTML			192.168.10.20	PH
56	http://192.168.10.20	GET	/dvwa/login.php		200	1599	HTML	php	Damn Vulnerable Web ...	192.168.10.20	
73	http://192.168.10.20	POST	/dvwa/login.php	✓	302	354	HTML	php		192.168.10.20	
74	http://192.168.10.20	GET	/dvwa/login.php		200	1638	HTML	php	Damn Vulnerable Web ...	192.168.10.20	
101	http://192.168.10.20	POST	/dvwa/login.php	✓	302	354	HTML	php		192.168.10.20	
102	http://192.168.10.20	GET	/dvwa/login.php		200	1638	HTML	php	Damn Vulnerable Web ...	192.168.10.20	

Request

Pretty | Raw | \n | Actions

```
1 GET /dvwa/ HTTP/1.1
2 Host: 192.168.10.20
3 Upgrade-Insecure-Requests: 1
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
  like Gecko) Chrome/89.0.4389.90 Safari/537.36 Edg/89.0.774.63
5 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;
  q=0.8,application/signed-exchange;v=b3;q=0.9
6 Referer: http://192.168.10.20/
7 Accept-Encoding: gzip, deflate
8 Accept-Language: ko,en;q=0.9,en-US;q=0.8
9 Connection: close
10
```

Response ❷

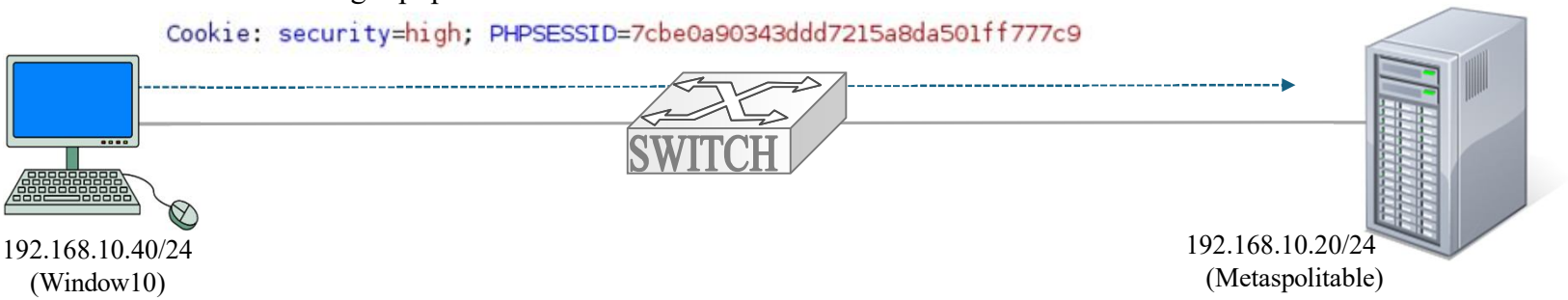
Pretty | Raw | Render | \n | Actions

```
1 HTTP/1.1 302 Found
2 Date: Thu, 08 Apr 2021 08:17:12 GMT
3 Server: Apache/2.2.8 (Ubuntu) DAV/2
4 X-Powered-By: PHP/5.2.4-2ubuntu5.10
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT
6 Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
7 Pragma: no-cache
8 Set-Cookie: PHPSESSID=7cbe0a90343ddd7215a8da501ff777c9; path=/
9 Set-Cookie: security=high
10 Location: login.php
11 Content-Length: 0
12 Connection: close
13 Content-Type: text/html
```

❸ Request

GET /dewa/login.php

Cookie: security=high; PHPSESSID=7cbe0a90343ddd7215a8da501ff777c9



55	http://192.168.10.20	GET	/dvwa/		302	445	HTML				192.168.10.20
56	http://192.168.10.20	GET	/dvwa/login.php		200	1599	HTML	php	Damn Vulnerable Web ...		192.168.10.20
73	http://192.168.10.20	POST	/dvwa/login.php	✓	302	354	HTML	php			192.168.10.20
74	http://192.168.10.20	GET	/dvwa/login.php		200	1638	HTML	php	Damn Vulnerable Web ...		192.168.10.20
101	http://192.168.10.20	POST	/dvwa/login.php	✓	302	354	HTML	php			192.168.10.20
102	http://192.168.10.20	GET	/dvwa/login.php		200	1638	HTML	php	Damn Vulnerable Web ...		192.168.10.20

Request ❸

Pretty | Raw | \n | Actions

```
GET /dvwa/login.php HTTP/1.1
Host: 192.168.10.20
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
 like Gecko) Chrome/89.0.4389.90 Safari/537.36 Edg/89.0.774.63
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;
q=0.8,application/signed-exchange;v=b3;q=0.9
Referer: http://192.168.10.20/
Accept-Encoding: gzip, deflate
Accept-Language: ko,en;q=0.9,en-US;q=0.8
Cookie: security=high; PHPSESSID=7cbe0a90343ddd7215a8da501ff777c9
Connection: close
```

Response

Pretty | Raw | Render | \n | Actions

```
HTTP/1.1 200 OK
Date: Thu, 08 Apr 2021 08:17:12 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Pragma: no-cache
Cache-Control: no-cache, must-revalidate
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Content-Length: 1289
Connection: close
Content-Type: text/html;charset=utf-8



<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.or

<html xmlns="http://www.w3.org/1999/xhtml">

  <head>

    <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
```